

DAY 4 – SOC INTERNSHIP

Types of Cyber Attacks + Detection Basics

1. Phishing Attack

What is Phishing?

Phishing is a type of social engineering attack in which an attacker tricks a victim into providing sensitive information or performing an action that benefits the attacker. The attacker may pretend to be a trusted person, company, bank, website, or service.

Information attackers may try to obtain:

- Usernames
- Passwords
- Banking information
- Credit/debit card details
- OTPs
- Personal information
- Account recovery information

Common Signs of Phishing

1. Fake Emails or Messages

An attacker may send a message pretending to come from a legitimate organization. For example: “Your bank account requires immediate verification.” The message may look professional but actually come from an attacker.

2. Urgent Language

Attackers often create a sense of urgency using phrases such as “Verify now,” “Your account will be suspended,” “Immediate action required,” or “You have only 24 hours.” The goal is to make the victim act without carefully checking the message.

3. Suspicious Links

A phishing message may contain a link that looks legitimate but redirects the victim to a fake website. Users should carefully check the actual destination and domain before clicking.

How Does a SOC Analyst Detect Phishing?

- Sender information
- Email headers
- URLs
- Domain names
- Attachments
- Message content
- Reported phishing emails
- User activity following the email

2. Malware Attack

What is Malware?

Malware means malicious software. It is software designed to harm, disrupt, exploit, or gain unauthorized access to a computer system.

A. Virus

A virus is malicious software that can spread and damage files. It may attach itself to legitimate files or programs and execute when the infected file is opened.

Possible effects:

- File corruption
- System instability
- Data loss
- Unwanted changes to files
- Reduced system performance

SOC indicators: unexpected file modifications, unusual processes, suspicious executable files, large numbers of files being changed, and endpoint security alerts.

B. Ransomware

Ransomware is malware that can lock or encrypt files and demand money from the victim.

Possible indicators:

- Large numbers of files suddenly becoming inaccessible
- Unusual file modifications
- Suspicious processes
- Security alerts
- Unexpected ransom messages
- Unusual network activity

SOC response focus: investigate the alert, identify the affected system, determine when activity started, check whether other systems are affected, and escalate the incident according to the organization's incident-response process.

C. Spyware

Spyware is malware designed to secretly monitor activity or steal information from a user or system.

Possible targets: user information, login credentials, browsing activity, and other sensitive data.

Possible SOC indicators: unexpected applications or processes, suspicious outbound network connections, unusual data transfers, endpoint security alerts, and unexpected changes to system configuration.

3. Brute-Force Attack

What is a Brute-Force Attack?

A brute-force attack is an attack where an attacker attempts many password combinations until the correct credentials are discovered.

Simple example: password123, admin123, welcome123, qwerty123, and other combinations.

Brute-Force Indicators

1. Repeated Login Failures

A large number of failed login attempts can indicate that someone is repeatedly trying different credentials.

```
10:01 - Login failed
10:02 - Login failed
10:02 - Login failed
10:03 - Login failed
10:03 - Login failed
```

2. Same IP Making Multiple Attempts

If many failed login attempts originate from the same IP address, it can be suspicious. A SOC analyst would investigate the pattern, but a failed login alone does not automatically mean an attack.

```
IP: 192.168.1.50
Failed login attempts: 150
Target account: admin
Time period: 5 minutes
```

4. SOC Detection Basics

A Security Operations Center (SOC) monitors an organization's systems and investigates suspicious security activity.

A. Monitor Logs for Unusual Activity

Logs are records generated by systems, applications, servers, network devices, and security tools. They can contain login attempts, IP addresses, timestamps, usernames, system events, errors, and network connections.

```
User: admin
IP: 203.0.113.10
Status: Failed Login
Time: 14:32
```

A SOC analyst can examine this information to identify suspicious patterns.

B. Identify Repeated Login Failures

Repeated login failures may indicate brute-force activity, password spraying, or simply a user repeatedly entering an incorrect password. The analyst should examine the number of attempts, source IP, target account, time period, and whether a successful login occurred afterward.

C. Check Suspicious Links or Emails

When an employee reports a suspicious email, a SOC analyst may investigate the sender, subject, URL, domain, attachment, message content, and other users who received the same message.

5. Attack Detection – Quick Comparison

Attack	Main Goal	Common Indicator
Phishing	Trick users into revealing information	Suspicious email/link
Virus	Can spread and damage files	Unexpected file changes
Ransomware	Lock/encrypt files and demand payment	Files become inaccessible
Spyware	Steal/monitor information	Suspicious processes/data transfer
Brute Force	Gain access through repeated password attempts	Many failed logins

6. Class Activity – Phishing Analysis

Message: “Your account will be suspended. Click here immediately to verify your details.”

Why does it look suspicious?

- **Urgent language:** “Your account will be suspended” creates fear and pressure.
- **Immediate action:** “Click here immediately” encourages the user to act without checking the message.
- **Request for verification:** The message asks the user to verify details, which could be an attempt to obtain sensitive information.

SOC perspective: A SOC analyst should investigate the sender, URL, domain, and other technical indicators before deciding whether the message is malicious.

7. Assignment

- Find a real phishing example online.
- Write three reasons why it is phishing.
- Explain how to prevent it.

Suggested prevention points:

- Do not click suspicious links.
- Verify the sender.
- Check the actual website/domain.
- Do not provide passwords or OTPs through suspicious messages.
- Report suspicious emails to the appropriate security team.

Assignment Answers

1. Real-World Phishing Example

Example: Fake Microsoft 365 account verification email. An employee receives an email that appears to come from Microsoft, saying:

Subject: Urgent: Your Microsoft 365 account will be suspended

Dear User,

Your Microsoft 365 account requires immediate verification. If you do not verify your account within 24 hours,

your account will be suspended.
Click here to verify your account.

Microsoft Support Team

The link takes the victim to a fake Microsoft login page designed to collect their username and password.

2. Three Reasons Why This Is Phishing

- **Urgent language** – The email says the account will be suspended within 24 hours, creating fear and pressure.
- **Suspicious link** – It asks the user to click a link to verify the account instead of directing them to the official Microsoft website manually.
- **Credential theft attempt** – The fake login page can be used to collect the user's Microsoft username and password.

3. How to Prevent It

- Do not click links in suspicious emails.
- Check the sender's email address carefully.
- Verify the website/domain before entering credentials.
- Open the official service website directly instead of using the email link.
- Never share passwords or OTPs through email.
- Report suspicious emails to the organization's IT/SOC team.

8. Key SOC Concepts to Remember

- **Phishing:** Tricks the user.
- **Malware:** Malicious software.
- **Virus:** Can spread and damage files.
- **Ransomware:** Locks/encrypts files and demands payment.
- **Spyware:** Secretly monitors or steals information.
- **Brute Force:** Repeatedly attempts passwords.
- **SOC Detection:** Monitor → Identify → Investigate → Respond/Escalate